

اعتبار رنجی ایران

خط مشی استفاده قابل قبول دارایی های اطلاعاتی

شماره مستند: ۶-ICS.ISMS.Assets Use Policy.V۰

نسخه: ۱۴۰۵/۰۳، ۶، ۰

عنوان مستند	تاریخ تصویب	طبقه‌بندی مستند
خط‌مشی استفاده قابل قبول دارایی‌های اطلاعاتی	۱۴۰۵/۰۳/۲۰	حساس
شماره مستند	شماره مستند	تعداد صفحات
ICS.ISMS.Assets Use Policy.V۰ - ۶	۶۰	۱۰

سابقه مستند

تاریخ	نام و نام خانوادگی	سمت	شرح	امضا
۱۴۰۵/۰۳/۱۶	داود اکبری	کارشناس مسئول GRC	تهیه مستند	
۱۴۰۵/۰۳/۱۸	مریم محمدنژاد زنجانی	مدیر طرح و برنامه	تأیید مستند	
۱۴۰۵/۰۳/۱۸	سهیلا خواجه‌حق‌ورودی	معاون پشتیبانی	تأیید مستند	
۱۴۰۵/۰۳/۱۸	محمد قربانی	معاون مالی و اداری	تأیید مستند	
۱۴۰۵/۰۳/۱۸	حامد احمدی	معاون فناوری اطلاعات	تأیید مستند	
۱۴۰۵/۰۳/۱۸	علیرضا پیلتن	مدیر تطبیق و امنیت اطلاعات	تأیید مستند	
۱۴۰۵/۰۳/۱۸	محسن صادقی	عضو موظف هیات‌مدیره	بازنگری و تأیید مستند	
۱۴۰۵/۰۳/۲۰	رضا قاسم‌پور	مدیرعامل و عضو هیات‌مدیره	تصویب مستند	

تغییرات مستند

شماره ویرایش	تاریخ	شماره بخش / بخش‌های تغییر یافته
۰۰۰	۱۴۰۱/۰۴/۱۳	پیش نویس اولیه
۱۰۰	۱۴۰۱/۱۲/۰۱	همگام سازی مستند با مستندات شرکت و متن پیشنهادی اولیه پذیرفته گردید.
۲۰۰	۱۴۰۲/۰۶/۰۶	اصلاح (بخش سخت‌افزار و پشتیبانی فنی) به واحد عملیات در متن سند، اصلاح در بند مربوط به رعایت خط مشی‌های امنیتی با متن «هرگونه ابهام

را با مدیر تطبیق و امنیت اطلاعات یا نماینده مدیریت در ISMS در جریان بگذارند»		
بازنگری سند مبتنی بر نسخه ۲۰۲۲ استاندارد تغییر در پیوست الف: کنترل‌های الف - ۸-۱-۳ به کنترل ۵/۱۰ و ۵/۱۱ در سند تغییر مسئولیت اجرای این خط مشی - افزوده شدن الزامات ایستگاه‌های کاری	۱۴۰۲/۱۱/۰۸	۳-۰
تغییر نام شرکت از «شرکت مشاوره رتبه‌بندی اعتباری ایران» به «شرکت اعتبارسنجی ایران»	۱۴۰۴/۰۵/۲۵	۴-۰
اضافه شدن الزاماتی جهت پشتیبان‌گیری از KeePass	۱۴۰۴/۱۱/۲۵	۵-۰
اضافه شدن ثبت تیکت‌ها در سامانه جیرا	۱۴۰۵/۰۳/۲۰	۶-۰

حق طبع و نشر

مالکیت مادی و معنوی این مستند منحصراً متعلق به «شرکت اعتبارسنجی ایران» است. بنابراین، انتشار مجدد این سند و یا استفاده از آن در سایر مستندات، به هر شکل اعم از الکترونیکی و کاغذی، بدون کسب اجازه کتبی از «شرکت اعتبارسنجی ایران» مجاز نبوده و منع قانونی دارد.

۱۴۰۵- شرکت اعتبارسنجی ایران

فهرست مطالب

- ۱- هدف ۱
- ۲- دامنه ۱
- ۳- مسئولیت‌ها و اختیارات ۱
- ۴- مراجع و مأخذ ۱
- ۵- تعاریف ۱
- ۶- خط‌مشی ۲
- ۷- یادداشت ۶
- ۸- مراجع، مستندات و پیوستها ۶

۱- هدف

هدف از تدوین و اجرای این خط‌مشی، طرح قوانین و مقررات برای استفاده مناسب و قابل قبول از اطلاعات و دارایی‌های وابسته به اطلاعات و یا تجهیزات وابسته به پردازش اطلاعات در شرکت اعتبارسنجی ایران به همراه حفظ الزامات امنیتی آن‌ها است.

۲- دامنه

این خط‌مشی برای تمامی کاربرانی که در قلمرو سیستم مدیریت امنیت اطلاعات از دارایی‌های اطلاعاتی شامل اطلاعات، تجهیزات و خدمات استفاده می‌کنند (شامل کارکنان، مشاوران و پیمانکاران)، کاربرد دارد.

۳- مسئولیت‌ها و اختیارات

مسئولیت اجرای این خط‌مشی بر عهده معاونین اداری و مالی و پشتیبانی با همکاری معاونت فناوری اطلاعات در دامنه سیستم مدیریت امنیت اطلاعات شرکت اعتبارسنجی ایران بوده و شامل کلیه پرسنل و پیمانکارانی است که به اطلاعات و دارایی‌های اطلاعاتی سازمان دسترسی دارند.

مسئولیت پایش این خط‌مشی و همچنین ممیزی‌های دوره‌ای و موردی/تصادفی بر عهده مدیریت تطبیق و امنیت اطلاعات است. این سند در فواصل زمانی سالیانه و یا در صورت ضرورت، با وصول درخواست تغییر مصوب، مورد بازنگری قرار می‌گیرد.

۴- مراجع و مأخذ

- استاندارد ۲۰۲۲: ISO/IEC ۲۷۰۰۱ کنترل ۵/۱۰ و ۵/۱۱
- طرح امن سازی زیرساخت های حیاتی در قبال حملات الکترونیکی نسخه ۲/۰ - محرمانه - بهمن ماه ۹۷
- چارچوب کنترل‌های امنیتی سازمانی و سامانه‌های اطلاعاتی - محرمانه - بهمن ۱۴۰۰

۵- تعاریف

- دارایی: هر چیزی که برای سازمان دارای ارزش است که در این سند منظور دارایی‌های مرتبط با تجهیزات فناوری اطلاعات است.

Asset

رضا قاسم‌پور

تصویب‌کننده

علیرضا پیلتن

تاییدکننده

محسن صادقی

بازنگری

- تسهیلات پردازش اطلاعات^۲: هر سامانه پردازش اطلاعات، تجهیزات فناوری اطلاعات، خدمت^۳، زیرساخت یا مکان‌های فیزیکی که موارد ذکر شده در آن قرار دارند.
- خدمات فناوری اطلاعات: شامل سرویس‌ها و امکانات نرم‌افزاری و ارتباطی است که جهت تسهیل انجام وظایف شغلی کارکنان به آنان ارائه می‌شود، شامل: پست الکترونیک، اینترنت، اینترنت، وب‌سایت، نرم‌افزارهای تخصصی، امکانات اشتراک فایل و پورتال‌های اطلاعاتی.
- کاربران: استفاده‌کنندگان از خدمات و تجهیزات، که شامل کلیه کارکنان (تمام‌وقت، پاره‌وقت)، مشاوران، تأمین‌کنندگان (خدمات و کالا)، پیمانکاران، مشتریان و کارآموزان مرتبط با قلمرو سیستم مدیریت امنیت اطلاعات شرکت اعتبارسنجی ایران است.
- الزامات امنیتی: منظور تمامی قواعد و نیازمندی‌های امنیتی است که در خط‌مشی‌ها، روش‌های اجرایی و دستورالعمل‌های مرتبط با سیستم مدیریت امنیت اطلاعات در شرکت تدوین، تصویب و ابلاغ شده‌اند.

۶- خط‌مشی

- کلیه کارکنان دامنه سیستم مدیریت امنیت اطلاعات شرکت اعتبارسنجی ایران باید استفاده صحیح و قابل‌قبول از خدمات و دارایی‌های سازمان را در اولویت کاری خود داشته باشند و در رعایت این خط‌مشی حداکثر تلاش خود را به‌کار ببندند. مسئولیت حفظ سلامت دارایی با مالک دارایی می‌باشد که در «دستورالعمل شناسایی و ارزش‌گذاری دارایی‌ها» ذکر شده است. در این راستا لازم است موارد ذیل رعایت شود:
- نحوه برخورد (کار) و استفاده از دارایی‌ها باید با توجه به نوع اطلاعات مرتبط با آن دارایی‌ها و جنبه اهمیت آن‌ها (اعم از محرمانگی، دسترس‌پذیری و صحت) باشد.
 - اهمیت دارایی‌ها و طریقه ارزش‌گذاری آن‌ها مطابق با روش اجرایی شناسایی و ارزش‌گذاری دارایی‌ها انجام می‌گردد.
 - ارزش هر دارایی و یا گروه دارایی با نسبت دادن پارامترهای محرمانگی و جامعیت و دسترسی‌پذیری محاسبه می‌گردد. هر چه شدت اثر ناشی از آسیب به یک دارایی (خسارات وارده) برای شرکت اعتبارسنجی ایران بیشتر باشد، برای آن دارایی در سیستم مدیریت امنیت اطلاعات ارزش بیشتری در نظر گرفته می‌شود و کنترل‌های امنیتی بیشتری برای حفظ آن دارایی به کار گرفته می‌شود.
 - از دارایی‌ها و خدمات شرکت اعتبارسنجی ایران جهت استفاده شخصی و خارج از اهداف کسب و کار سازمان، استفاده نگردد.
 - از واگذاری دارایی‌ها و خدمات سازمان به افراد غیرمجاز جلوگیری شود.

^۲ Information Processing Facilities

^۳ Service

- استفاده صحیح از دارایی‌ها و خدمات شرکت اعتبارسنجی ایران به گونه‌ای باشد که موجب خرابی و آسیب دیدگی نگردد.
 - از قرارگرفتن دارایی‌ها در معرض ضربه، گرد و خاک، ریختن مایعات و یا هرگونه استفاده نابه‌جا که منجر به آسیب آن‌ها می‌شود، جلوگیری گردد.
 - از دستکاری و یا باز نمودن در پوش محفوظه^۴ تجهیزات در صورت بروز خرابی خودداری شود؛ در این‌گونه موارد لازم است به جای اقدام شخصی، مراتب به مسئول مربوطه (واحد عملیات) ارجاع داده شود.
 - کارکنان موظف هستند در هنگام ترک محل کار نسبت به خاموش یا **standby** نمودن سیستم کاربری خود اقدام نمایند.
- کاربران تنها مجاز به استفاده از دارایی‌هایی هستند که یا مالک آن‌ها بوده و یا مجوز استفاده از آن‌ها را در اختیار دارند.
- همه کاربران در تذکر و گزارش ضعف‌ها و رویدادهای امنیتی (که ناشی از استفاده غیر ایمن و نامناسب از دارایی‌ها است) به همکاران و یا مراتب بالاتر، با احترام متقابل و اخلاق پسندیده رفتار نموده و در محیطی اخلاقی و در قالب مشارکت گروهی، از بروز رفتارهای نامناسب جلوگیری کنند. در صورتی که تذکرات داده شده به همکاران مورد توجه قرار نگرفت، مراتب به مدیر هر واحد گزارش شود و ایشان بایستی مراتب را به اطلاع نماینده مدیریت در **ISMS** برساند.
- اشخاص ثالثی که از دارایی‌های سازمان استفاده می‌کنند یا به آن دسترسی دارند، از ملاحظات امنیتی و مسئولیت‌های خود در رابطه با دارایی‌ها و منابع، آگاه گردند (مطابق با خط‌مشی امنیت در روابط با تأمین‌کنندگان و توافق‌نامه عدم افشای اطلاعات^۵). مسئولیت این امر بر عهده مدیر تطبیق و امنیت اطلاعات می‌باشد.
- کپی و تکثیر هرگونه اطلاعات، برنامه، مستندات و موارد مشابه (نظیر برنامه‌های دارای مجوز و برنامه‌های توسعه‌یافته در داخل ایران که دارای مجوز هستند) که مشمول قانون کپی‌رایت و یا قانون جرائم رایانه‌ای کشور می‌باشند، ممنوع است.
- تحت هیچ شرایطی، کاربران، حق شرکت در فعالیتهایی غیرقانونی را به هنگام استفاده از منابع سازمان ندارند و نباید باعث خدشه‌دار شدن نام و اعتبار سازمان شوند (مستند مصادیق جرائم و رعایت اخلاق رایانه‌ای).

^۴Case^۵ NDA= Non-Disclosure Agreement

رضا قاسم‌پور

علیرضا پیلتن

محسن صادقی

تصویب‌کننده

تاییدکننده

بازنگری

- علاوه بر موارد ذکرشده در این مستند، هر فرد بایستی تلاش خود را برای حفظ امنیت اطلاعات به‌کار گیرد.
- خط‌مشی‌ها، روش‌های اجرایی و دستورالعمل‌های الزام شده سیستم مدیریت امنیت اطلاعات باید رعایت شوند تا کمک مؤثری جهت استفاده قابل قبول از دارایی‌ها و خدمات فناوری اطلاعات باشد.
- معاون اداری و مالی موظف است به‌محض استخدامی‌های جدید اعم از دائمی، قراردادی، پیمانکاری، خط‌مشی استفاده قابل قبول از دارایی‌ها را آموزش و گوشزد کند.
- نصب هرگونه ابزار در روی ایستگاه‌های کاری و لپ‌تاپ‌ها یا تبلت‌ها از طریق مدیریت زیرساخت و شبکه صورت گرفته و صرفاً از بین ابزارهای مجاز سازمانی باید انجام شود.
- کلیه ایستگاه‌های کاری سازمانی باید متصل به **Active Directory** سازمان باشند.
- تمامی حساب‌های کاربری مورد استفاده باید تحت دامنه بوده و از بکارگیری حساب‌های کاربری محلی اجتناب شود.
- ابزار آنتی ویروس و **DLP** بر روی کلیه ایستگاه‌های کاری سازمانی نصب شود.
- اطلاعات حساب کاربری و رمز عبور بر روی مرورگرها ذخیره نشده، جهت نگهداری از رمز عبور از ابرازی مانند **KeePass** استفاده شود. مدیر هر واحد موظف است از **KeePass**‌های کاربران، در بازه‌های ۳ ماهه، نسخه پشتیبان تهیه نموده و این نسخه در نزد گاو صندوق مدیرعامل شرکت ذخیره گردد.
- به هنگام تبادل فایل بر روی ایستگاه‌های کاری، از پاک بودن فایل‌ها با کمک آنتی ویروس اطمینان حاصل شود.
- کارکنان موظف هستند همواره آخرین نسخه به‌روز از مستندات سیستم مدیریت امنیت اطلاعات را مطالعه کرده و به الزامات آن پایبند باشند.
- کارکنان و پیمانکاران موظف‌اند به محض اتمام همکاری‌شان با سازمان، تمامی دارایی‌های تحت مالکیتشان را به سازمان عودت دهند (خط‌مشی امنیت اطلاعات در مدیریت منابع انسانی فناوری اطلاعات).
- رسانه‌های حاوی اطلاعات باید در برابر دسترسی غیرمجاز، سوءاستفاده یا خرابی در حین انتقال محافظت شوند (مطابق خط‌مشی امنیتی رسانه‌های سیار).
- کارکنان موظف‌اند رسانه‌ها را با استفاده از رویه‌های رسمی، زمانی که دیگر به آن‌ها نیازی ندارند به طور امن امحاء کنند (مطابق با خط‌مشی امنیتی امحاء دارایی‌های اطلاعاتی).
- جهت جلوگیری از خرابی دارایی‌ها یا صدمه به آنها در صورت استفاده نابجا، راهنمای استفاده از دارایی‌ها، فناوری‌ها و محدودیت‌های آن مدون و اطلاع‌رسانی شود.
- در صورت تشخیص مولفه (دارایی) غیرمجاز، اقدامات امنیتی مقتضی انجام شود.

۶-۱ سامانه جیرا

سامانه جیرا برای ثبت و مدیریت وظایفی که در شرکت ایجاد می‌گردد، بکار گرفته می‌شود. و بایستی برای تمامی فرآیندهای شرکت، الزامات زیر رعایت شود.

- ثبت اطلاعات در این سامانه بایستی به صورت کامل و با خوانایی لازم انجام شود. ارجاع تیکتها، بایستی همراه با درج توضیح به شخص یا واحد دیگر صورت پذیرد. و به عبارت دیگر تیکت به صورت بدون توضیح گردش نداشته باشد.
- شرایط خاتمه تیکت با ذکر دلیل خاتمه و دریافت مجوز لازم، صورت پذیرد. و شخص خاتمه دهنده تیکت، شخص مجاز (تعیین افراد مجاز با مدیریت هر واحد می باشد) برای خاتمه آن تیکت باشد.
- برای تیکتهای ثبت شده در جیرا مهلت انجام عملیات (OLA) توسط مدیریت طرح و برنامه و با هماهنگی با واحد مربوطه لحاظ شود.
- جهت کاهش زمان انجام تیکتها، از درج تیکتهایی که شامل چند بخش هستند خودداری شود و این تیکتها به چند تیکت کوچکتر تبدیل شود تا زمان اجرای هر تیکت کاهش یافته و مدیریت این تیکتها آسان تر باشد.
- از ازای کلیه فرآیندها، تیکت مجزا و مشخص تعریف شود.
- حتی امکان قالب فعالیتهای شرکت باید در قالب فرآیند در جیرا تعریف شوند.
- سوابق فایل‌ها با طبقه بندی محرمانه که در چرخه فرآیند جیرا قرار می‌گیرند به صورت رمز شده در سامانه جیرا بارگذاری و تبادل شوند
- کلیدهای تولید شده بدین منظور توسط هر واحد نگهداری و مدیریت شود و یک نسخه پشتیبان از کلیدها در اختیار مدیریت هر واحد قرار گیرد. (مطابق با خط مشی رمزنگاری)
- گزارش ماهیانه OLA توسط مدیریت طرح و برنامه به مدیر عامل ارائه شود.

۶-۲ رعایت خط‌مشی‌های امنیتی

جهت ارتقاء آگاهی کارکنان از مسائل امنیت اطلاعات، خط‌مشی‌ها، روش‌های اجرایی و دستورالعمل‌هایی که تدوین گردیده است، آشنایی و رعایت قواعد آن‌ها با توجه به وظایف و نقش کاربران الزامی است؛ لذا تمامی کاربران بایستی نسبت به قوانین مندرج در آن‌ها آگاهی کامل داشته و هرگونه ابهام را با مدیر تطبیق و امنیت اطلاعات یا نماینده مدیریت در ISMS در جریان بگذارند. این مستندات کنترل‌های استاندارد را در حوزه‌های زیر پوشش می‌دهند:

- خط‌مشی‌های امنیت اطلاعات
- سازمان امنیت اطلاعات
- امنیت منابع انسانی

- مدیریت دارایی‌ها
- کنترل دسترسی
- رمزنگاری
- امنیت فیزیکی و محیطی
- امنیت عملیات
- امنیت ارتباطات
- اکتساب، توسعه و نگهداری سیستم‌های اطلاعاتی
- روابط با تأمین‌کنندگان
- مدیریت حوادث امنیت اطلاعات
- جوانب امنیت اطلاعات در مدیریت تداوم کسب و کار
- انطباق با الزامات قانونی و قراردادی

۷- یادداشت

بدیهی است با موارد مکشوفه تخطی از هر یک از موارد فوق، مطابق با دستورالعمل انضباطی امنیت اطلاعات سازمان برخورد خواهد شد و در صورت نیاز به مراجع دارای صلاحیت ارجاع می‌شود و مطابق با قوانین حقوقی با خاطی یا خاطیان رفتار می‌گردد.

۸- مراجع، مستندات و پیوست‌ها

لیست نرم افزارهای مجاز	ICS.IS.Licen&Ulicen soft LIST.V۰-۱

<پایان مستند>